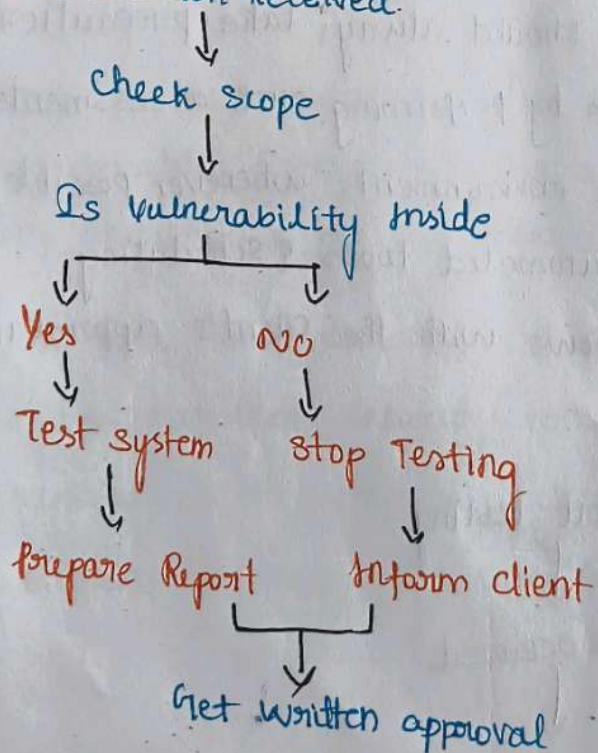


- 1) A Company hires you to test its network but gives only a one-line email authorization with no defined scope. During testing, you discover a critical vulnerability outside the mentioned scope. Should you exploit it?

Ethical hacking is the process of identifying security weakness in a computer system with the owner's permission. Before starting any penetration test, the scope of testing must be clearly defined on agreement. In this scenario, the company has provided only a critical vulnerability is discovered in a system that is outside the agreed scope. Even though the vulnerability is serious, an ethical hacker should never exploit it without obtaining additional written permission from the client.

Flowchart :

Authorization Received



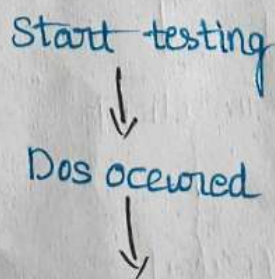


Exploiting a system outside the authorized scope may violate legal regulations and cloud results in damage to the client's infrastructure. Instead, the ethical hacker should immediately document the finding, notify the client about the issue & request permission before continuing any further disclosure. Ethical hackers must always act honestly, respect client boundaries, maintain confidentiality & unnecessary harm.

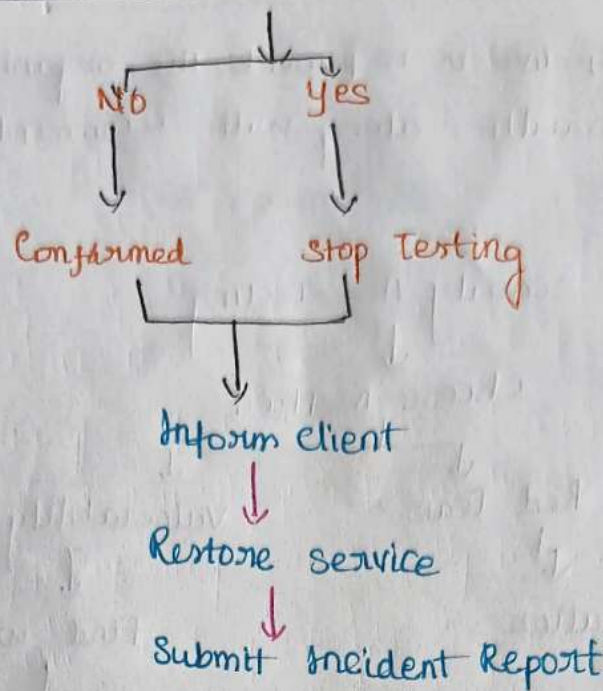
2) During a penetration test, you accidentally trigger a Denial of Service Condition on a live production server causing an outage. Explain how it could have been prevented?

A Denial of Service Condition occurs when a server becomes unavailable because it is overloading with requests or unexpected traffic. During penetration environment. Ethical hackers should always take precautions to prevent such incidents by performing risk assessments, testing in non-production environments whenever possible, limiting the speed of automated tools & scheduling test tests during windows with the client's approval.

Flowchart ÷







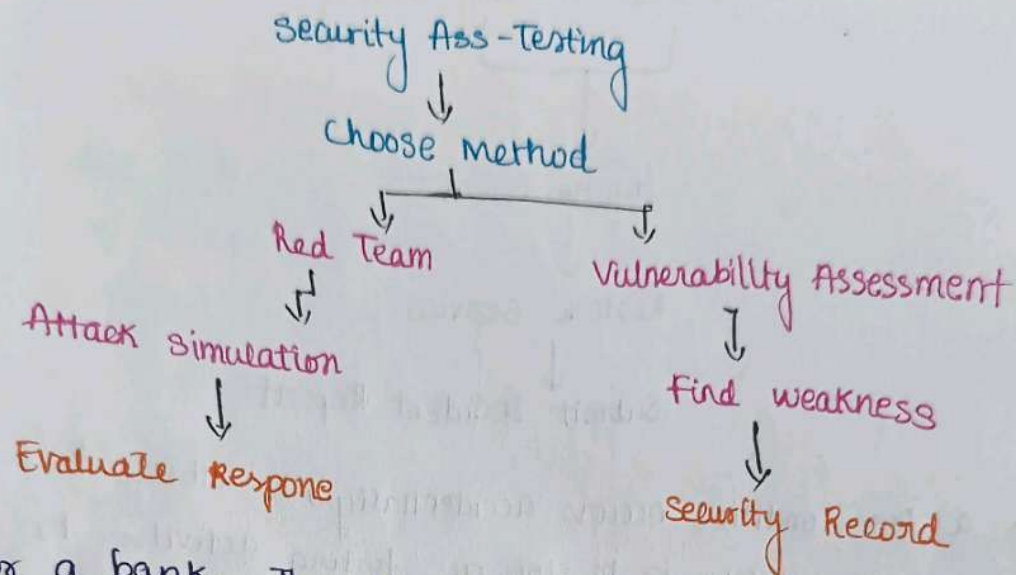
If a DoS Condition occurs accidentally, the ethical hacker's first responsibility is to stop all testing activities to immediately. The incident should be reported to the client without delay. The tester should then be prepared explaining what happened. Taking responsibility of a hacker.

Explain the difference between a Red Team Exercise and a vulnerability Assessment for a bank wanting to test both physical & digital security?

A Red Team exercise & a vulnerability assessment are two different security testing approaches used by organizations to improve cyber security. A Vulnerability Assessment focuses on identifying weaknesses in systems.



The main objective is to provide the organization with a list of vulnerabilities along with recommendations for fixing them.

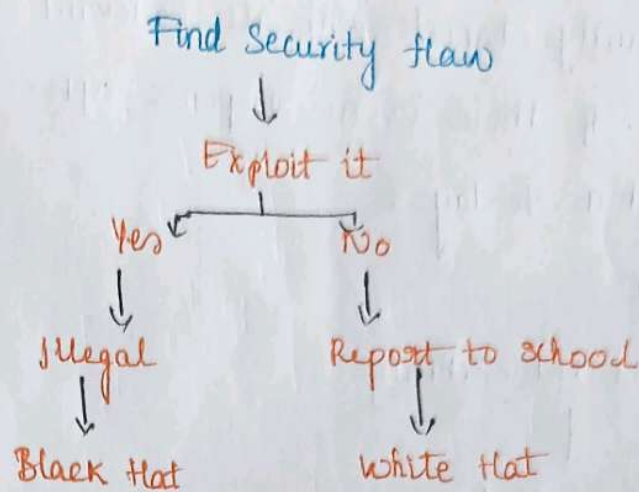


For a bank, The red Team may attempt phishing attacks, physical entry into buildings or network intrusions to measure the effectiveness of existing security measures.

4) A person discovers a flaw in their school's grading portal and quietly reports it to the administration instead of exploiting it?

The individual should be classified as a white hat hacker, also known as an ethical hacker, white hat use their technical knowledge to improve security flaw but chose not to exploit it for personal benefits. Instead, the issue was reported to the

school administration so that it could be fixed before the misused it.



- 5) You discover a critical zero-day vulnerability in widely used medical device software. The vendor does not respond for 90 days. Explain the responsible process.

Responsible disclosure is a cyber security practice in which researcher privately report security vulnerabilities to the software vendor before making the information public. The purpose is to give the vendor enough time to investigate the issue, develop a security patch & protect users from potential attacks. In this scenario, a critical zero-day vulnerability has been identified in medical device software, but the vendor has not responded even after 90 days.

The researchers should first verify the vulnerability



Carefully & Prepare detailed documentation explaining its impact. The Vendor should then be contacted through office security channels with all relevant technical information. If there is no response after a reasonable period, such as 90 days.

Flow chart:-

